otris compliance
Digitale GRC-Prozesse

Hinweisgebersystem nach EU-Richtlinie 2019/1937

Carsten Belzer, Ulrich Palmer

Agenda

EU-Whistleblower-Richtlinie

otris Hinweisgebersystem

Anonymität und Datensicherheit

Betriebsmodelle

Partnerprogramm Hinweisgebersystem

Ausblick otris Compliance-Suite

otris software

EU-Whistleblower-Richtlinie

EU-Richtlinie 2019/1937

Ziel der „Whistleblower-Richtlinie“: Schutz von Personen, die Verstöße melden.

Grundsätzliche Zielsetzung:

- Schutz der Personen, die Verstöße gegen das Unionsrecht melden
- Meldungen über interne Kanäle (auch anonym) zu fördern
- Öffentliche Meldung sollen nur in Ausnahmefällen erfolgen
- Verpflichtung zur Hinweisbearbeitung in vorgegebenen Fristen

EU-Richtlinie 2019/1937

Was müssen Unternehmen beachten?

- Unternehmen müssen anonyme Meldekanäle anbieten, um Hinweisgeber zu schützen
- Frist für Unternehmen ab 250 Mitarbeiter: 17.12.2021
- Frist für Unternehmen ab 50 Mitarbeiter: 17.12.2023
- Fristen gelten auch für Gemeinden mit mindestens 10.000 Einwohner
- Detaillierte Infos: EU-Richtlinie 2019/1937

otris software

otris Hinweisgebersystem

Motivation

Mit dem otris Hinweisgebersystem:

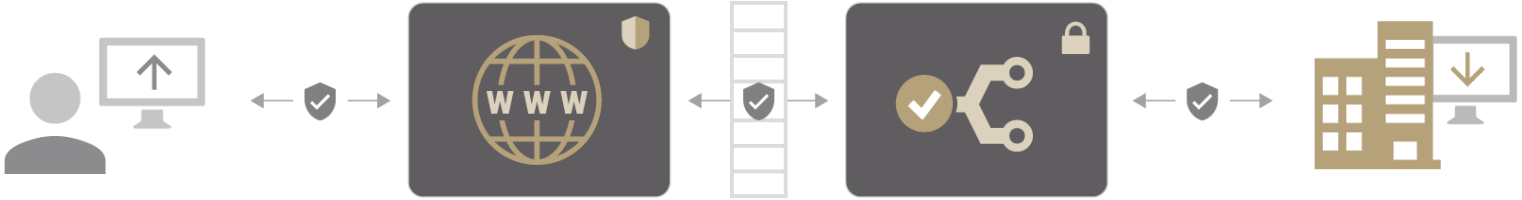
- Gesetzliche Standards und Normen einhalten
- Von Hinweisen profitieren / Missstände beseitigen
- Externe Meldungen an Behörden oder Presse verhindern
- Unternehmenserfolg und Reputation sichern
- Technischen Aufwand klein halten

Hinweisgeberschutz

Hinweisgeber

Hinweisempfänger

otris Hinweisgebersystem



Hinweisgeber

- Öffnet Meldeplattform
- Gibt Hinweis ab
- Kommuniziert über anonymes Postfach mit Empfänger

Meldeplattform

- Garantiert Anonymität und Datenschutz
- Betrieb durch neutrale Instanz in der Cloud

Case-Management

- Strukturiert Hinweise
- Automatisiert Bearbeitungs-prozesse
- Betrieb in der Cloud oder On-Premises

Hinweisempfänger

- Bearbeitet Hinweise im Case-Management
- Kommuniziert über anonymes Postfach mit Hinweisgeber

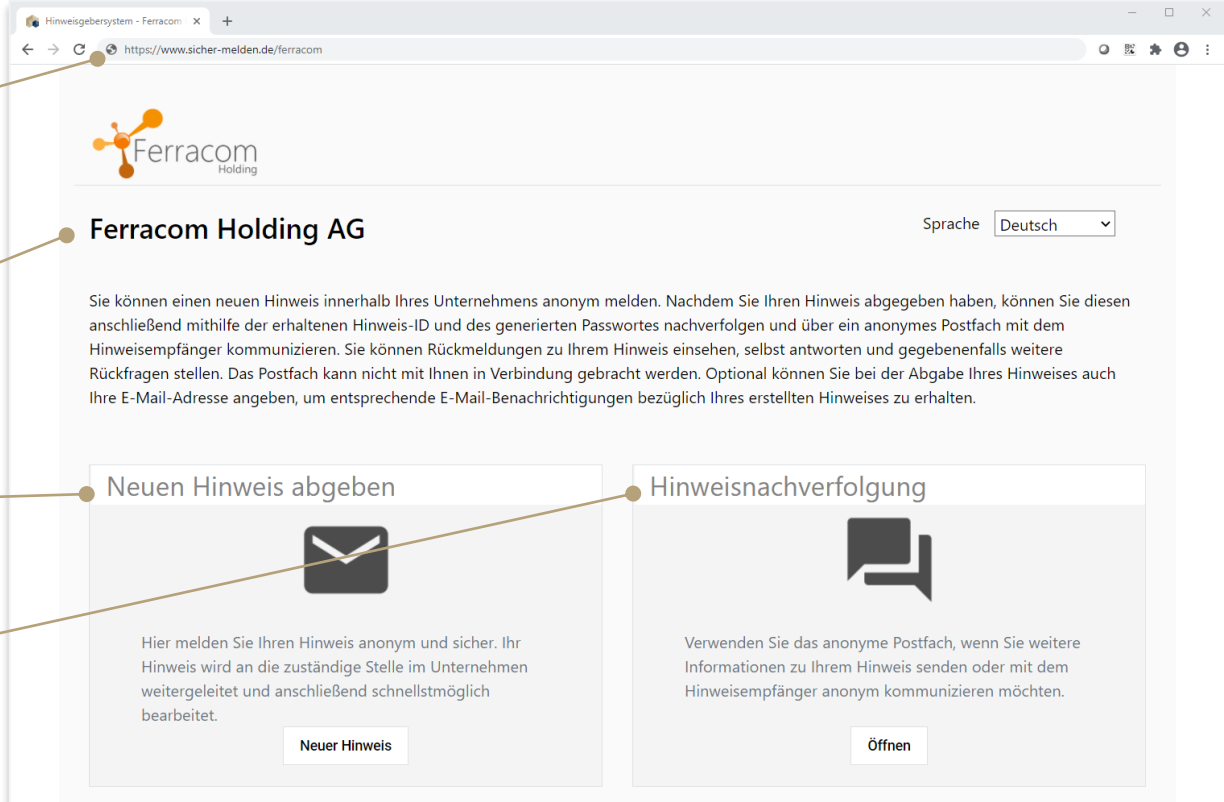
Meldeplattform

Webbasiert
Über Web-Browser erreichbar

Individuell anpassbar
Texte, Logos, Sprachauswahl

Hinweis melden
Anonym und sicher

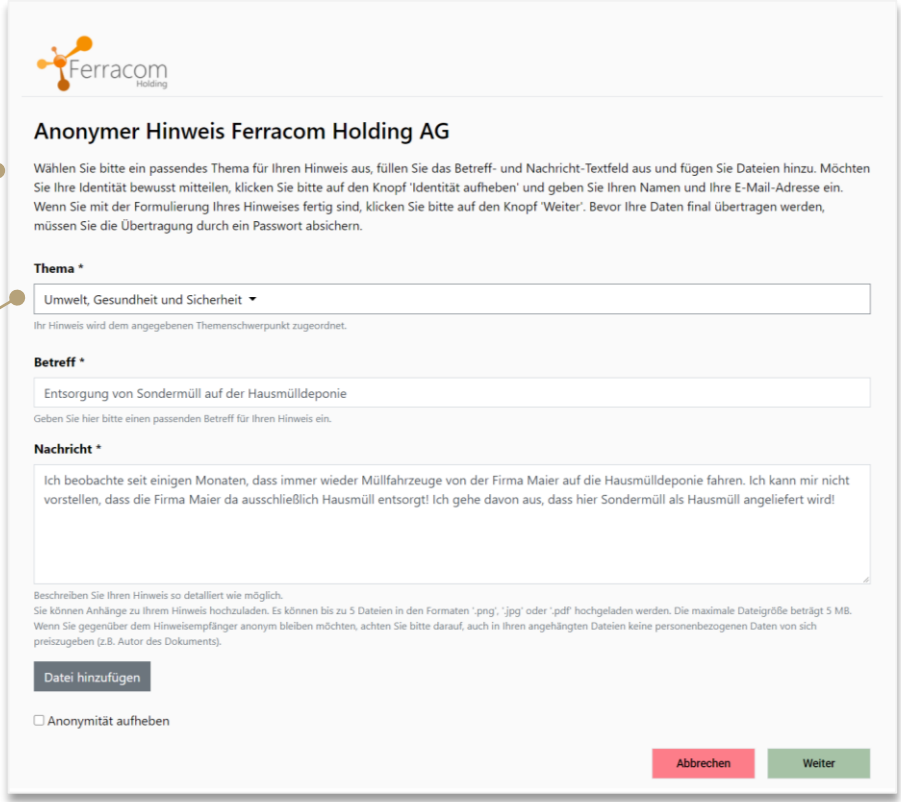
Hinweis nachverfolgen
Anonymes Postfach



Meldeplattform / Hinweis abgeben

Hinweis erfassen
Anonym und sicher

Auswahlliste
Administration der Themen im Case-Management

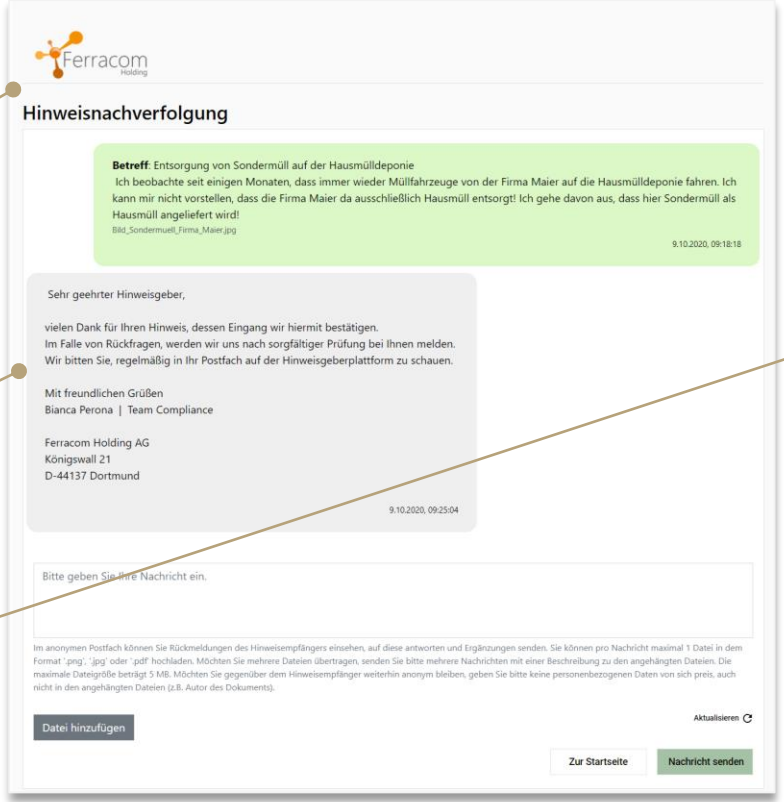


Meldeplattform / Hinweis nachverfolgen

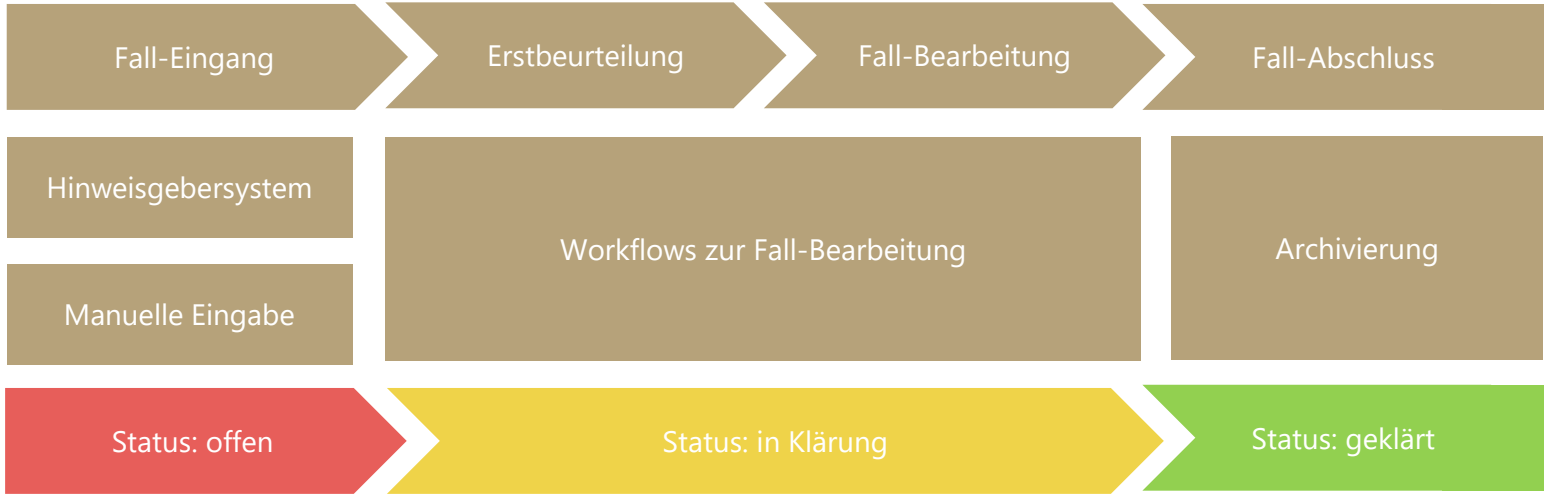
Anonymes Postfach
Bearbeitungsstatus / Kommunikation zwischen Hinweis-geber und Hinweis-empfänger

Datenschutz
Kommunikation ist hochverschlüsselt

Mobil
Alle Funktionen auch mit mobilen End-geräten nutzbar



Case-Management



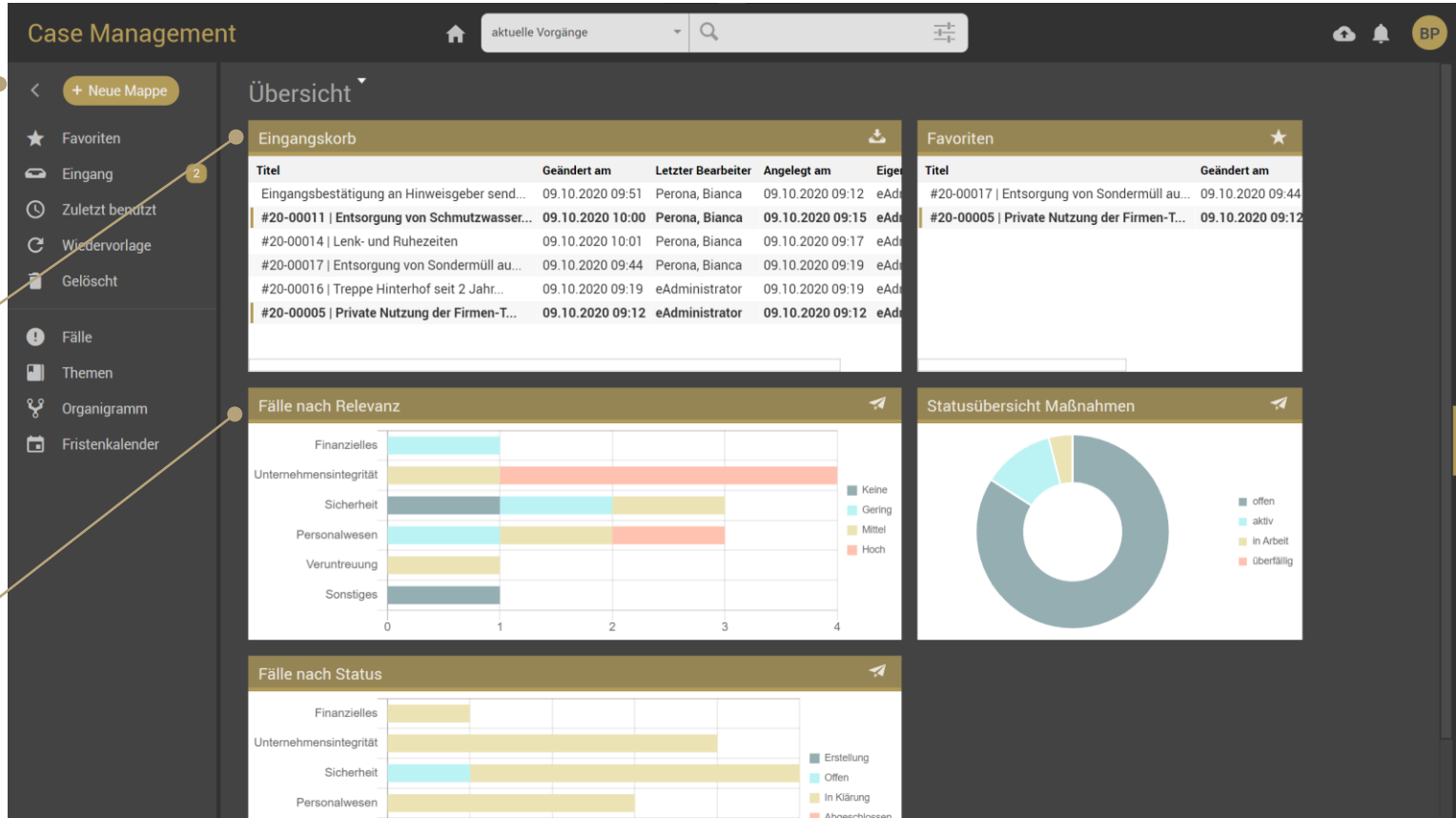
otris software

Dashboard Case-Management

Dashboard
Echtzeit-Statistiken; übersichtliche Reports

Teambezogenen Eingangskörbe
Zur sicheren und schnellen Fallbearbeitung

Grafische Auswertungen
Z.B. Fälle sortiert nach Relevanz/Status; Statusübersicht der Maßnahmen



otris software

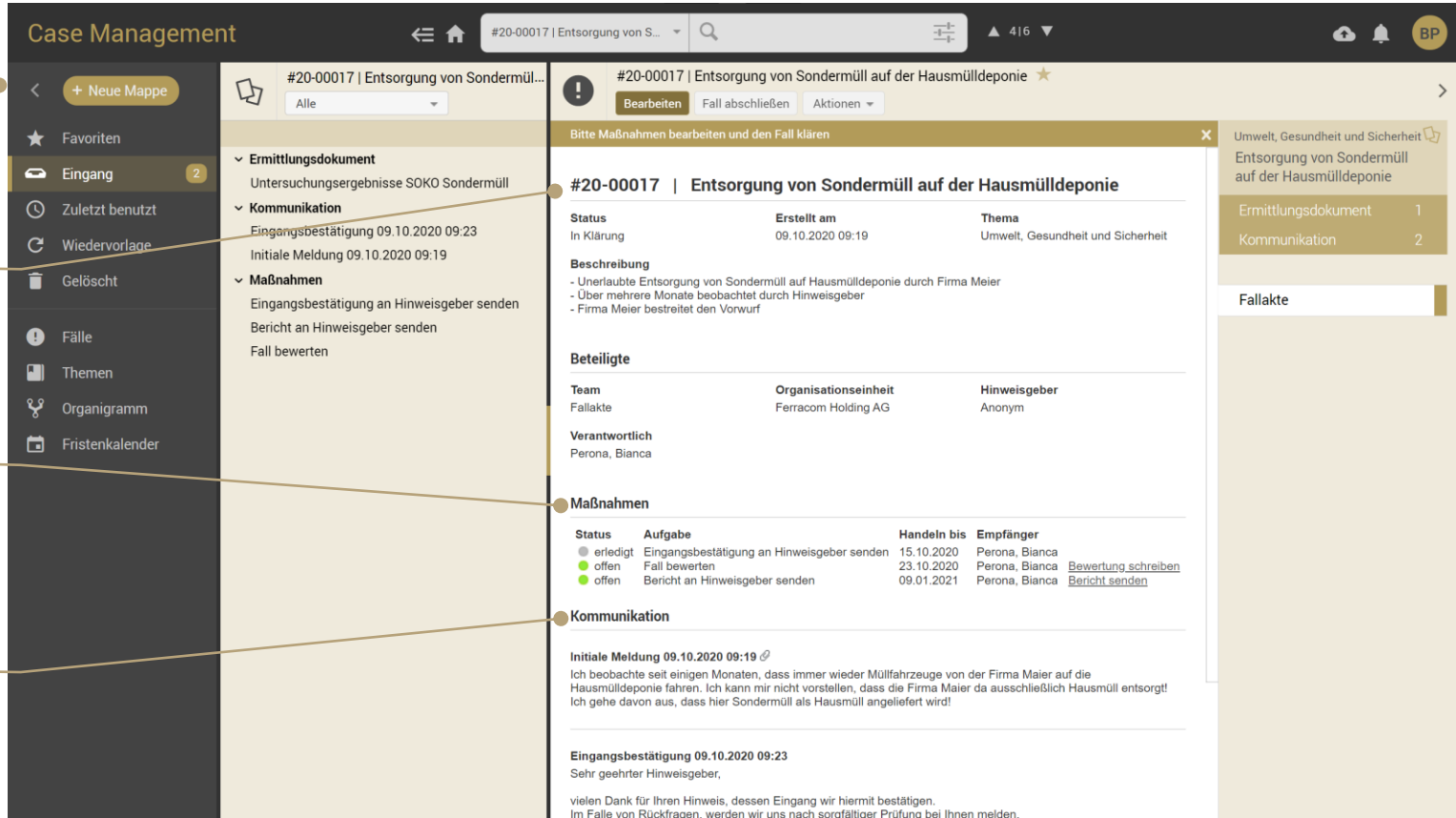
Fallakte Case-Management

Einfacher u. sicherer Zugriff auf Informationen
Browserbasiert

Übersichtliche Darstellung der Kerninformationen

Maßnahmen zuweisen
Bearbeitung systematisch nachverfolgen

Kommunikation mit dem Hinweisgeber
Über E-Mail-Vorlagen

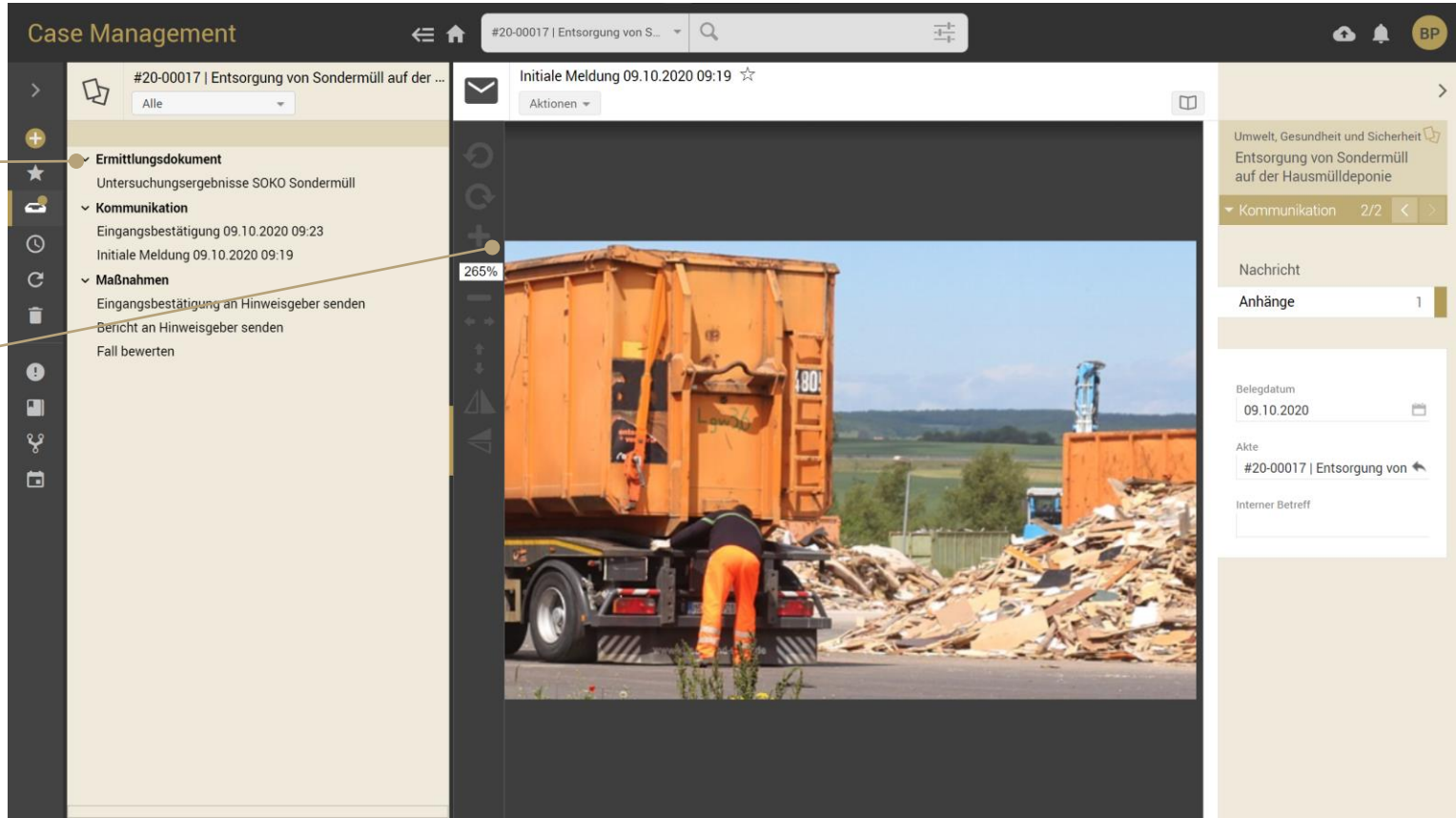


otris software

Inhaltsverzeichnis Case-Management

Inhaltsverzeichnis
Über die gesamte Fallakte

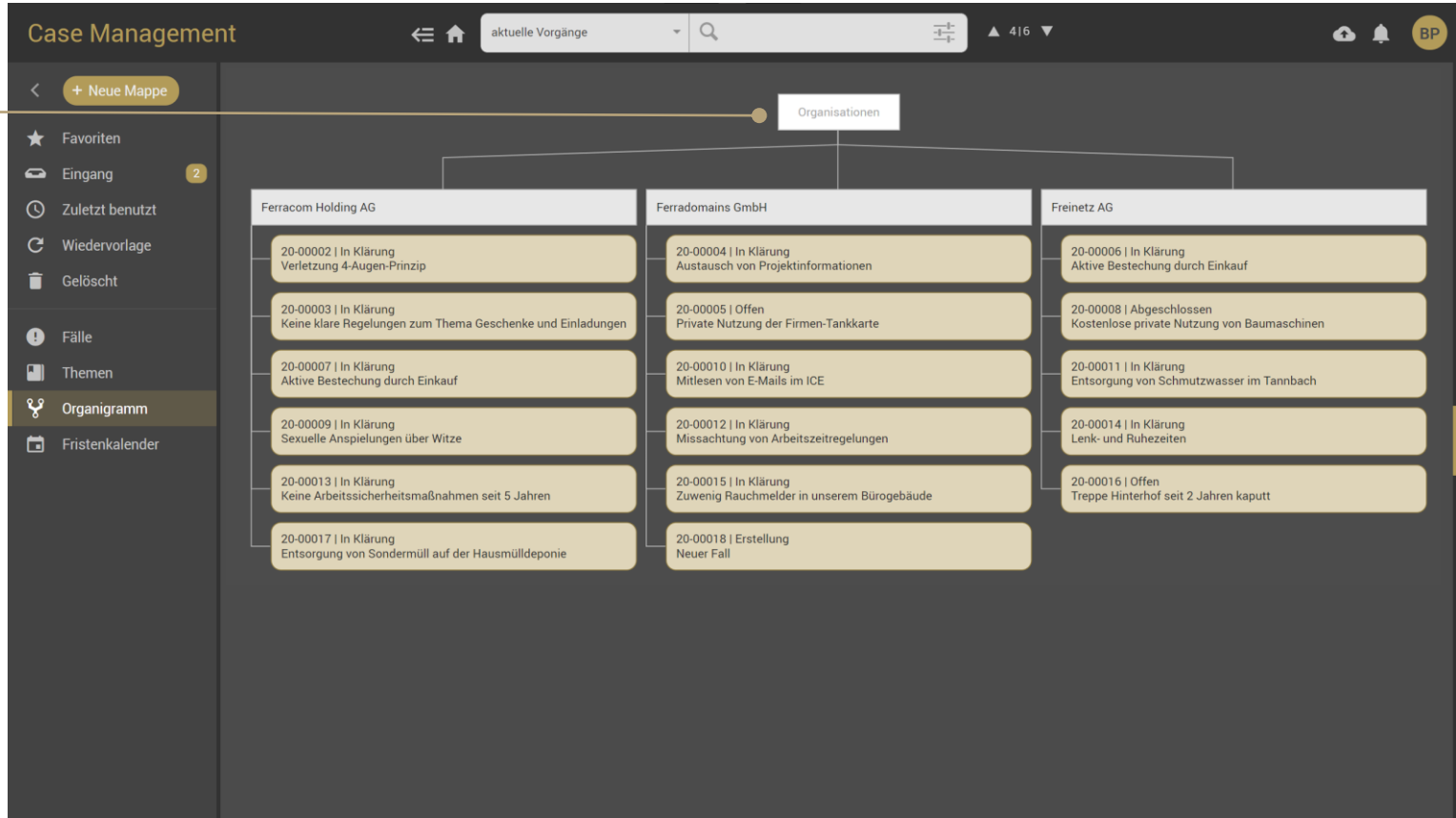
Anhänge
Als Beweismittel



otris software

Organigramm Case-Management

Mehrmandanten-
fähigkeit



otris software

Anonymität und Datensicherheit

Anonymität und Datensicherheit

Höchste Priorität: Hinweisgeberschutz

- Ein Hinweis ist nur vom Hinweisgeber und zugehörigem Backend lesbar
- Betreiber der Plattform kann keine Inhalte mitlesen
- Keine Protokollierung der IPs
- Anonyme Kommunikation zwischen Hinweisgeber und -empfänger
- Übertragung von Hinweisen an das Case-Management über TAN Verfahren

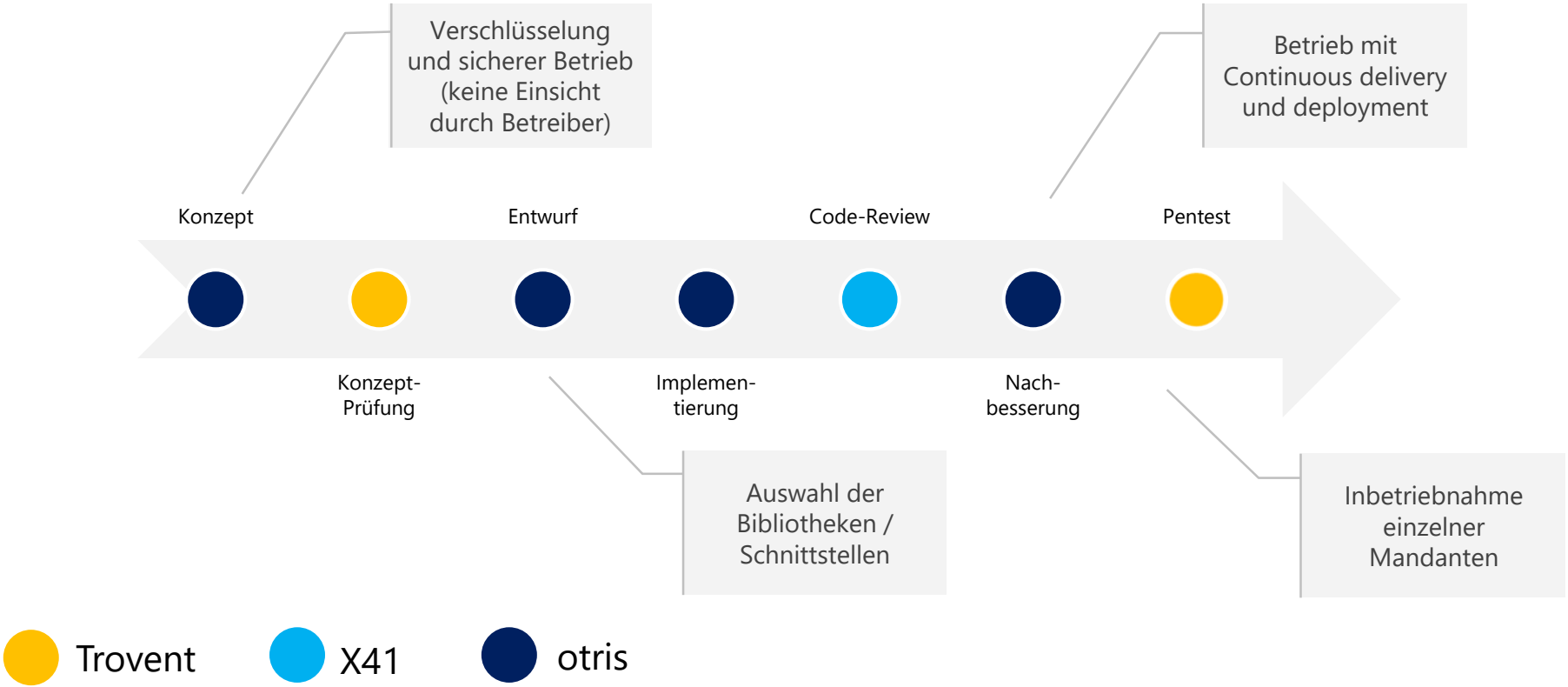
➔ **Sichere anonyme Plattform für Hinweisgeber**

Anonymität und Datensicherheit

Technischer Schutz des Hinweisgebers

- Ende zu Ende Verschlüsselung zwischen Browser Meldeplattform und Case-Management
  - Ähnlich einer Web „Public Key Infrastruktur“
  - Asymmetrische Verschlüsselung (RSA 4096)
  - Signierung der Datensätze
  - Symmetrische Verschlüsselung (AES-256-GCM)
  - BSI-konform (Richtlinie - Kryptographische Verfahren: Empfehlungen und Schlüssellängen)
- Transportverschlüsselung
  - Verschlüsselungsverfahren (TLS1.3)
  - Begrenzte Cipher-Suites (TLS_AES_128_GCM_SHA256:TLS_AES_256_GCM_SHA384:TLS_CHACHA20_POLY1305_SHA256)
  - Perfect Forward Secrecy
  - BSI-konform (Mindeststandard des BSI zur Verwendung von Transport Layer Security (TLS))

Anonymität und Datensicherheit



Anonymität und Datensicherheit

TROVENT

Security Audit Confirmation

Trovent Security GmbH confirms the successful completion of a

Security Concept Review,

Penetration Test and

Code Review

of otris software AG's

otris whistleblowing reporting channel

(Hinweisgebersystem-Meldeplattform)

TROVENT SECURITY AUDIT

Sicher in der otris-Cloud

otris software

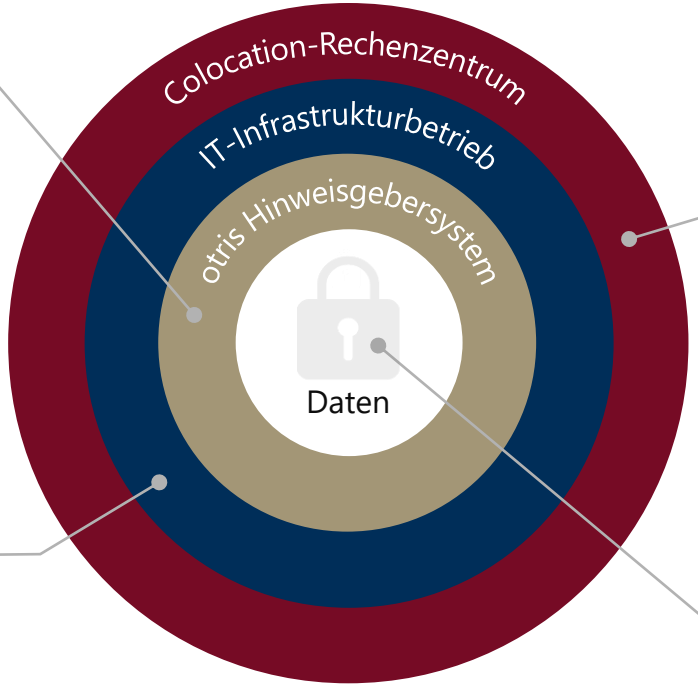
otris software AG
- Entwickelt die Fachlösung
- Lässt Fachlösung zertifizieren (Pentests und Prüfung des IT-Sicherheitskonzepts)
- Verankert Datenschutz und IT-Sicherheit auf Vertragsebene
- Absolviert regelmäßig Datenschutzaudits
- Hat keinen Zugriff auf Daten durch Support und Consulting ohne AV-Vertrag

TROVENT SECURITY AUDIT

bytemine
Ein Unternehmen der otris-Gruppe

bytemine GmbH
- Verantwortlich für Cloud-Infrastruktur, Security-Updates und 24/7 Betrieb
- Verantwortlich für sicheren Betrieb, Verfügbarkeit und rollierende Backups
- Absolviert regelmäßig Datenschutzaudits
- Beschäftigt TÜV-zertifizierten ISB

TÜVRheinland®
Genau. Richtig.



Colocation-Rechenzentrum
- Kein Serverzugriff (Server-Housing)
- ISO/IEC 27001:2013 Zertifizierung
- ISO 9001:2015 Zertifizierung

TÜV SÜD ISO 27001 TÜV SÜD ISO 9001

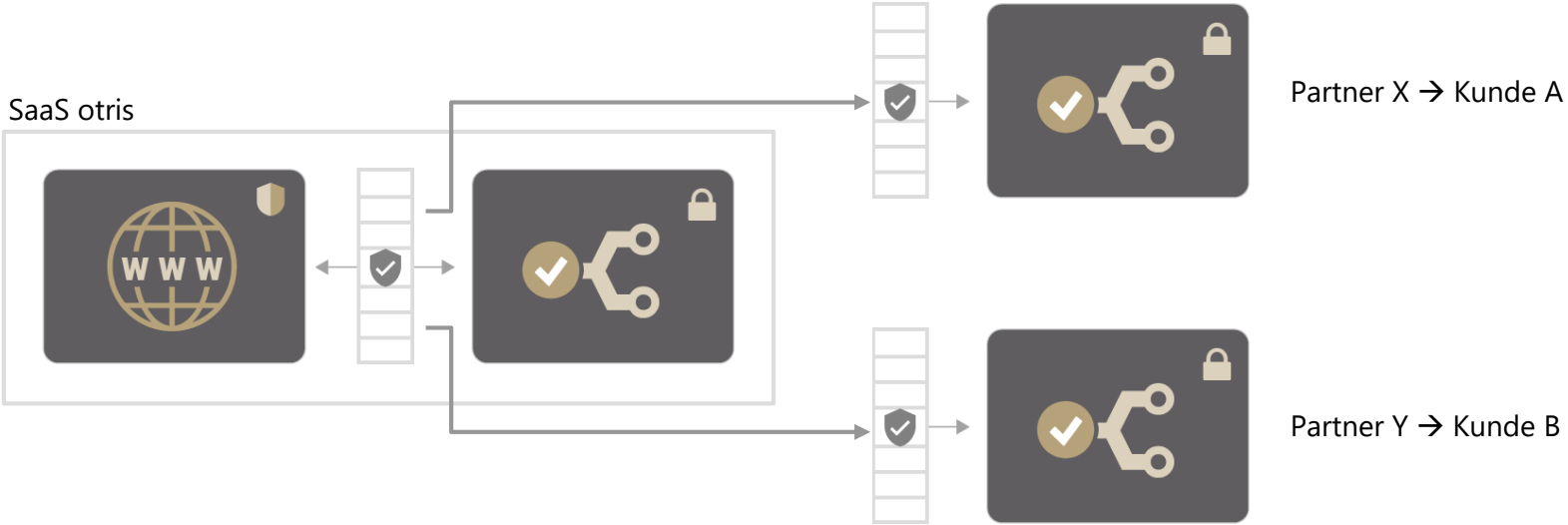
Cloud-Kunde der otris
Zugriff über Nutzer-Account
- Optional: VPN-Anbindung
- Optional: Zwei-Faktor-Authentisierung

Betriebsmodelle

Betriebsmodelle

Hinweisgebersystem

- otris compliance – Meldeplattform (immer SaaS bei der otris software AG)
- otris compliance – Case-Management (SaaS bei der otris software AG oder on premises beim Kunden)



Betriebsmodelle

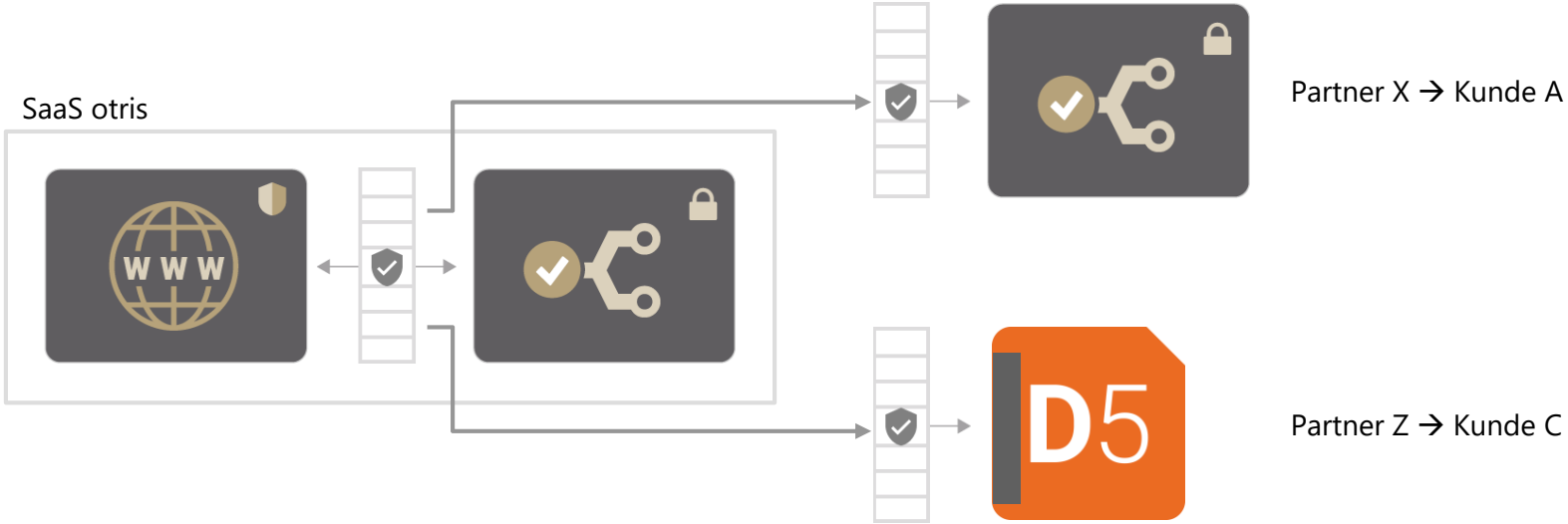
Monitoring Meldeplattform

- Anmeldungen durch Case-Management können verarbeitet werden
- Health-Check des Systems
- Problemmeldungen beim Betrieb der Meldeplattform

Betriebsmodelle für die Zukunft

Integration in eigene Lösung

- otris compliance – Meldeplattform (SaaS bei der otris software AG)
- DOCUMENTS - Meldeplattform Client API



otris software

Partnerprogramm Hinweisgebersystem

Partnerprogramm Hinweisgebersystem

Vertrieb

- Eine Meldeplattform in der Demo-Umgebung (www.sicher-melden-demo.de)
- Ein Case-Management in der Demo-Umgebung (case1-demo.otris.cloud)
- Voraussetzung: Schulung des Vertriebs durch die otris software AG

Consultant

- Sicher das otris compliance – Case-Management
  - installieren
  - einführen (Datenschutz und sonstige notwendige fachlichen Einstellungen)
  - konfigurieren
  - erweitern
- Voraussetzung: Schulung der Consultants durch die otris software AG

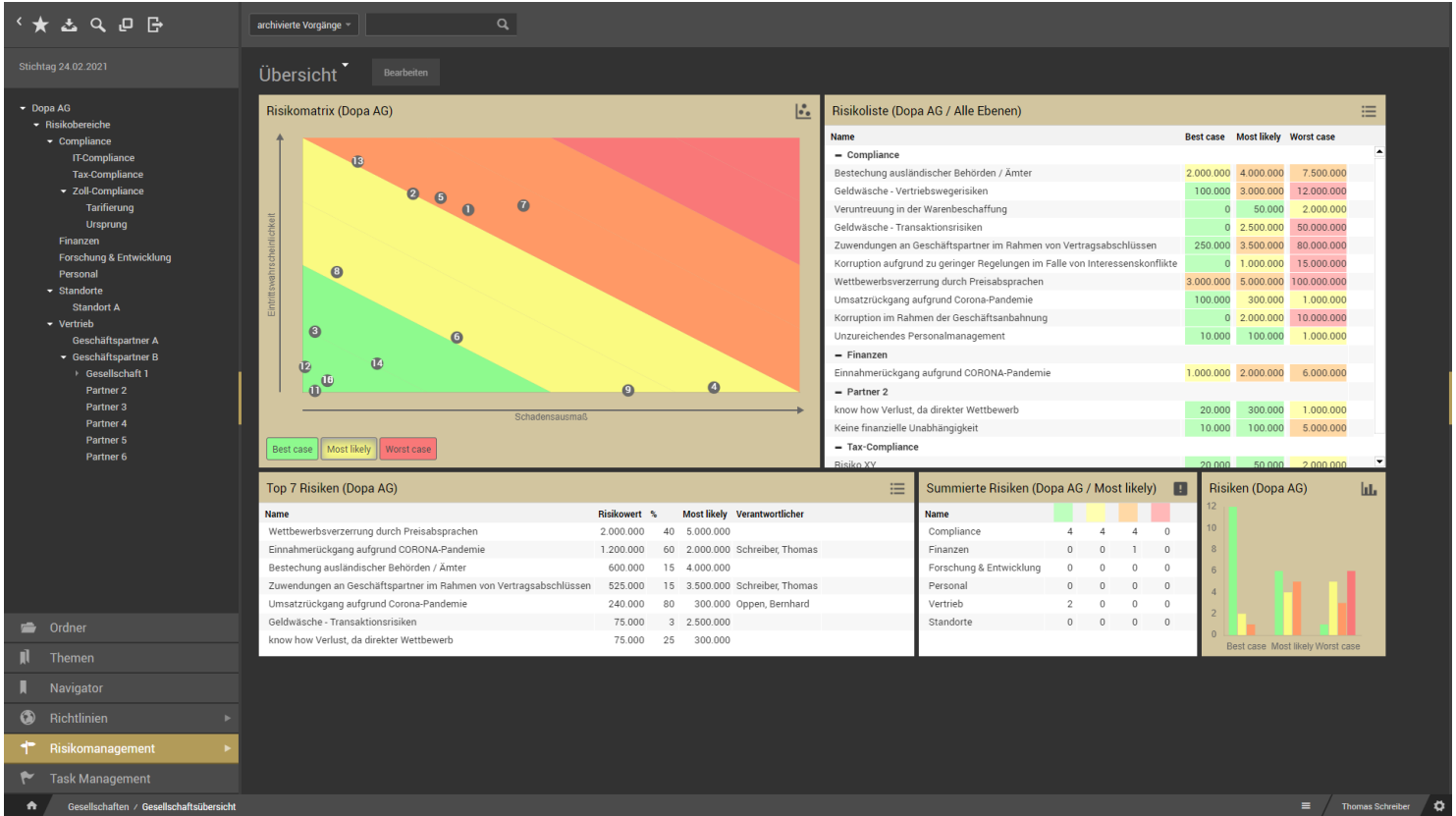
Partnerprogramm Hinweisgebersystem

Implementierungspartner

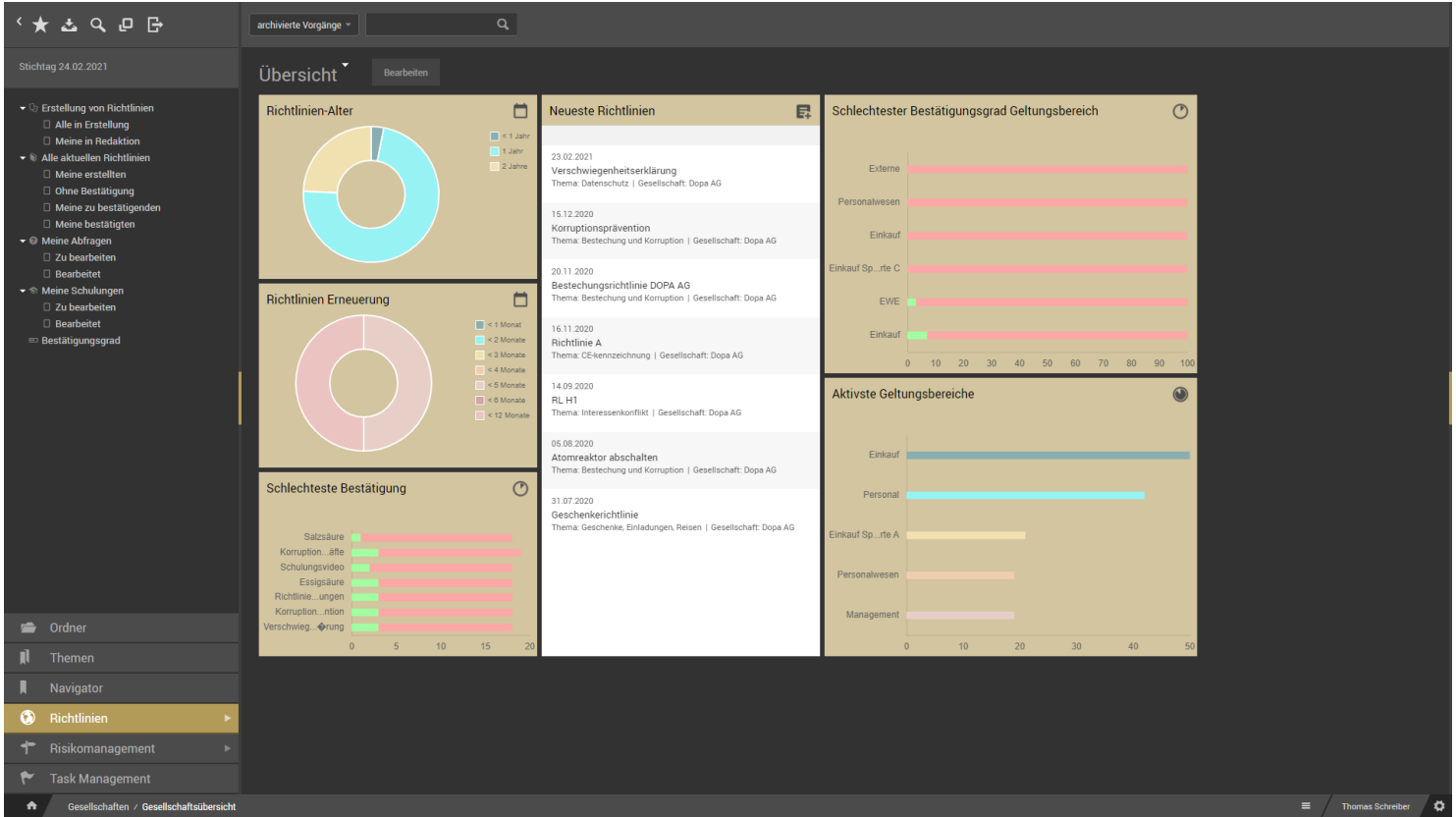
- Meldeplattform
  - REST Services
  - Verschlüsselungskonzept
- DOCUMENTS - Meldeplattform Client API
  - Einbindung der API in eigene Projekte
  - Komponenten
- Voraussetzung: Schulung der Implementierungspartner durch die otris software AG

Ausblick
otris Compliance-Suite

otris compliance – Risikomanagement



otris compliance - Richtlinienmanagement



Compliance-Suite

Meldeplattform
Anonyme Fall/Hinweiserfassung und Postfach

Risiko
Assessment, Dokumentation, Maßnahmen

otris compliance
Digitale GRC-Prozesse

Richtlinien
Dokumentation, Freigabe, Verteilung

CASE-Management
Fallbearbeitung, Dokumentation, Maßnahmen

Fragen

Ihre Ansprechpartner heute

otris software
vereinfacht Verantwortung.

DANKE!

otris contract
Vertragsmanagement

otris corporate
Beteiligungsmanagement

otris compliance
Digitale GRC-Prozesse

otris privacy
Datenschutzmanagement

otris dossier
Digitale Aktenlösungen

Ulrich Palmer, Carsten Belzer

palmer@otris.de / belzer@otris.de
www.otris.de

otris software AG
Königswall 21
44137 Dortmund

© copyright by otris software AG. Vervielfältigung auch auszugsweise nur durch die schriftliche Genehmigung der otris software AG